TPE SUR LE CHAPITRE 2 : JOURNAUX D'EVENEMENT : COLLECTE, NORMALISATION ET INTEGRITE

ENONCE DES EXERCICES

Ex. 2.1 — Analyse d'un fichier access.log. À partir du fichier fourni en TP, identifiez : (a) les IP générant le plus de codes 401 ; (b) les URI cibles de tentatives SQLi ; (c) les User-Agents suspects. Produisez une fiche d'alerte de 10 lignes.

Ex. 2.2 — Configuration Rsyslog. Rédigez /etc/rsyslog.d/50-siem.conf pour qu'un Ubuntu 22.04 expédie vers le SIEM (10.0.0.5:6514 TCP TLS) tous les journaux de niveau warning et supérieur, avec file d'attente persistante de 10 000 messages.

Ex. 2.3 — Analyse de la timeline. À partir du tableau 2.6 : (a) durée entre le premier scan et la première connexion réussie ; (b) EID confirmant l'effacement ; (c) technique MITRE du mouvement latéral ; (d) deux mesures qui auraient interrompu la chaîne dès l'étape 3.

Exercice 2.1 — Analyse d'un fichier access.log

Introduction

Les journaux Apache access.log constituent une source essentielle pour la détection d'attaques web. Leur analyse permet d'identifier les comportements suspects tels que les tentatives d'authentification répétées, les injections SQL ou l'utilisation de User-Agents malveillants. Dans le cas de LiZbiZ-SIS, cette étape est cruciale pour protéger le serveur web exposé en DMZ.

Développement

- **(a) IP générant le plus de codes 401** : ces adresses révèlent des tentatives d'accès non autorisées ou des attaques par brute force.
- **(b) URI cibles de tentatives SQLi** : recherche de chaînes suspectes (' OR 1=1, UNION SELECT, --) dans les requêtes GET/POST.
- **(c) User-Agents suspects** : détection de scanners automatisés (ex. sqlmap, curl, python-requests).

Une **fiche d'alerte de 10 lignes** doit synthétiser : IP source, fréquence des erreurs, URI ciblées, User-Agents détectés, gravité estimée, recommandation (blocage IP, durcissement authentification).

Conclusion

L'analyse d'access.log permet de transformer des données brutes en indicateurs de compromission exploitables. La fiche d'alerte constitue un outil opérationnel pour le SOC, facilitant la détection précoce des attaques web et l'application de contre-mesures adaptées.

Exercice 2.2 — Configuration Rsyslog

Introduction

La collecte centralisée des journaux est indispensable pour garantir leur intégrité et permettre une corrélation efficace dans le SIEM. Rsyslog, largement utilisé sous Linux, offre des mécanismes de transmission sécurisée via TCP/TLS et de résilience en cas de coupure réseau.

Développement

Exemple de configuration /etc/rsyslog.d/50-siem.conf pour Ubuntu 22.04 :

- **Destination** : SIEM à l'adresse 10.0.0.5:6514 via TCP/TLS.
- **Filtrage** : expédition des journaux de niveau **warning et supérieur**.
- **Résilience** : file d'attente persistante de 10 000 messages.
- **Sauvegarde locale** : conservation 30 jours pour éviter la perte en cas de coupure.

Cette configuration garantit la confidentialité (TLS), l'authenticité (certificats mutuels) et la disponibilité (queue persistante).

Conclusion

La mise en place d'un pipeline Rsyslog sécurisé et résilient constitue une étape clé vers un SOC de niveau 2. Elle assure la centralisation fiable des journaux, condition indispensable pour la détection et la corrélation dans LiZbiZ-SIS.

Exercice 2.3 — Analyse de la timeline

Introduction

La construction d'une timeline multi-sources permet de reconstituer la chronologie d'une attaque et d'identifier les points de rupture possibles. Elle est essentielle en analyse forensique pour comprendre la séquence des événements et proposer des mesures correctives.

À partir du tableau 2.6 :

- **(a) Durée entre le premier scan et la première connexion réussie** : calcul du temps écoulé, indicateur du MTTD.
- **(b) EID confirmant l'effacement** : par exemple **Windows EID 1102** (journal Sécurité effacé).
- **(c) Technique MITRE du mouvement latéral** : **T1021.002 — SMB/Windows Admin Shares**.
- **(d) Deux mesures qui auraient interrompu la chaîne dès l'étape 3** :
    1. Mise en place d'une règle de corrélation SMB (détection de connexions multiples).
    2. Blocage réseau via firewall ou segmentation stricte entre VLAN utilisateurs et serveurs.

Conclusion

L'analyse de la timeline révèle les failles de détection et les opportunités manquées pour interrompre l'attaque. En intégrant les bons EID et en appliquant des mesures préventives, LiZbiZ-SIS peut réduire son dwell time et renforcer sa posture de défense proactive.